

OpenID Connect

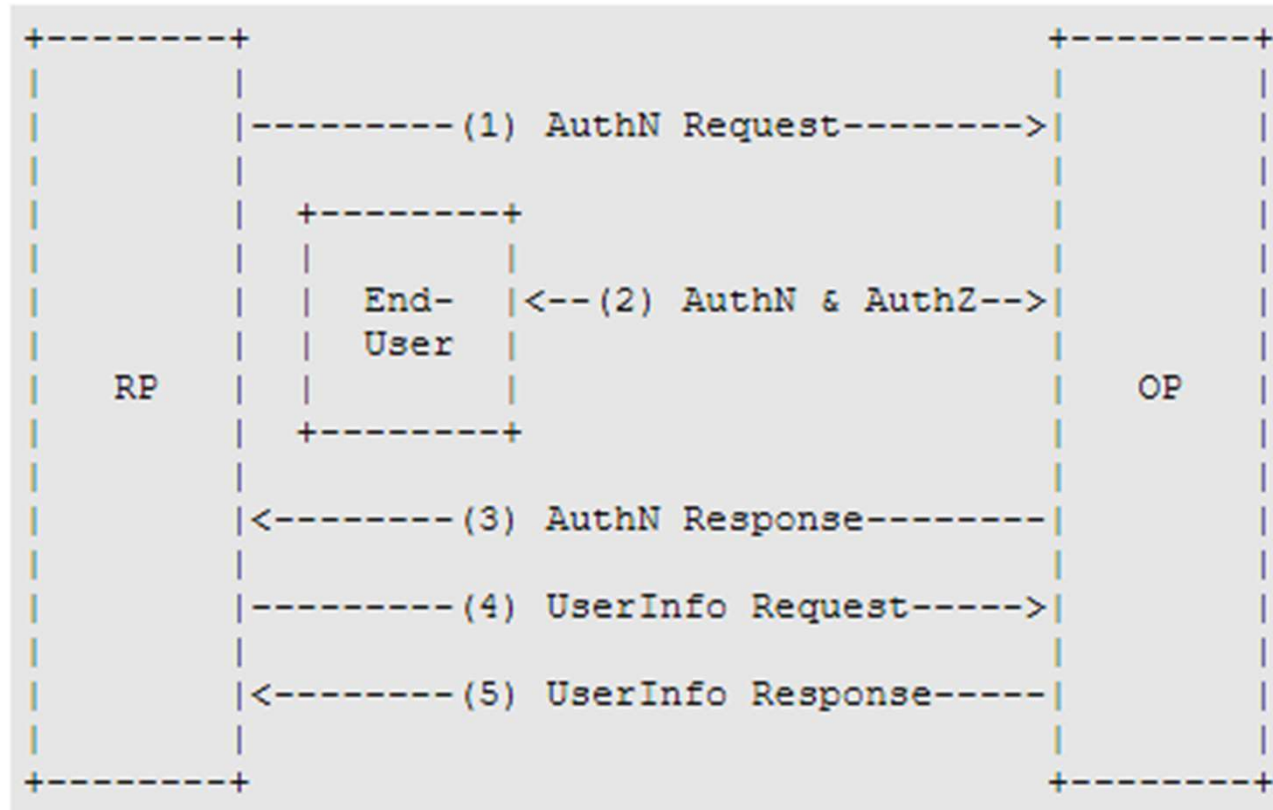
Introdução ao protocolo para delegação de autenticação em ambientes *web*

Participantes

- Utilizador (*End-User*)
 - Utilizador humano que pretende aceder a um serviço na aplicação cliente
 - A aplicação cliente apenas fornece o serviço a utilizadores autenticados
 - Caso prático com utilizador a aceder via browser
- Aplicação cliente (*Relying Party*)
 - Aplicação cliente que fornece o serviço
 - Delega no fornecedor de identidade a autenticação do utilizador
- Fornecedor de identidade (*Identity Provider*)
 - Guarda registo do utilizador e da sua informação de autenticação (password, certificado, ...)
 - Guarda registo de aplicações cliente que pretendam autenticar utilizadores

Visão geral dos passos do protocolo

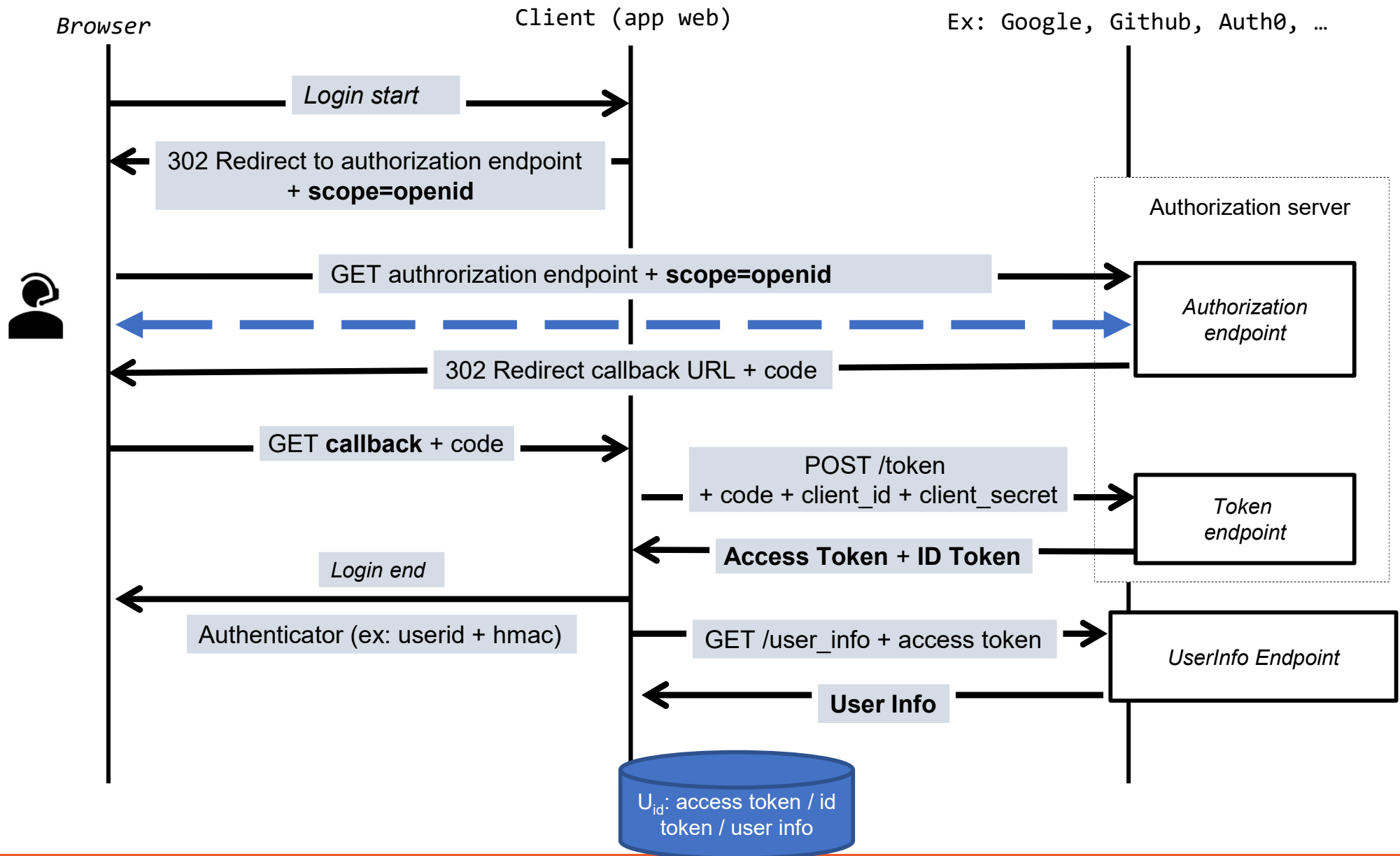
- https://openid.net/specs/openid-connect-core-1_0.html#Overview



RP - *Relying Party*

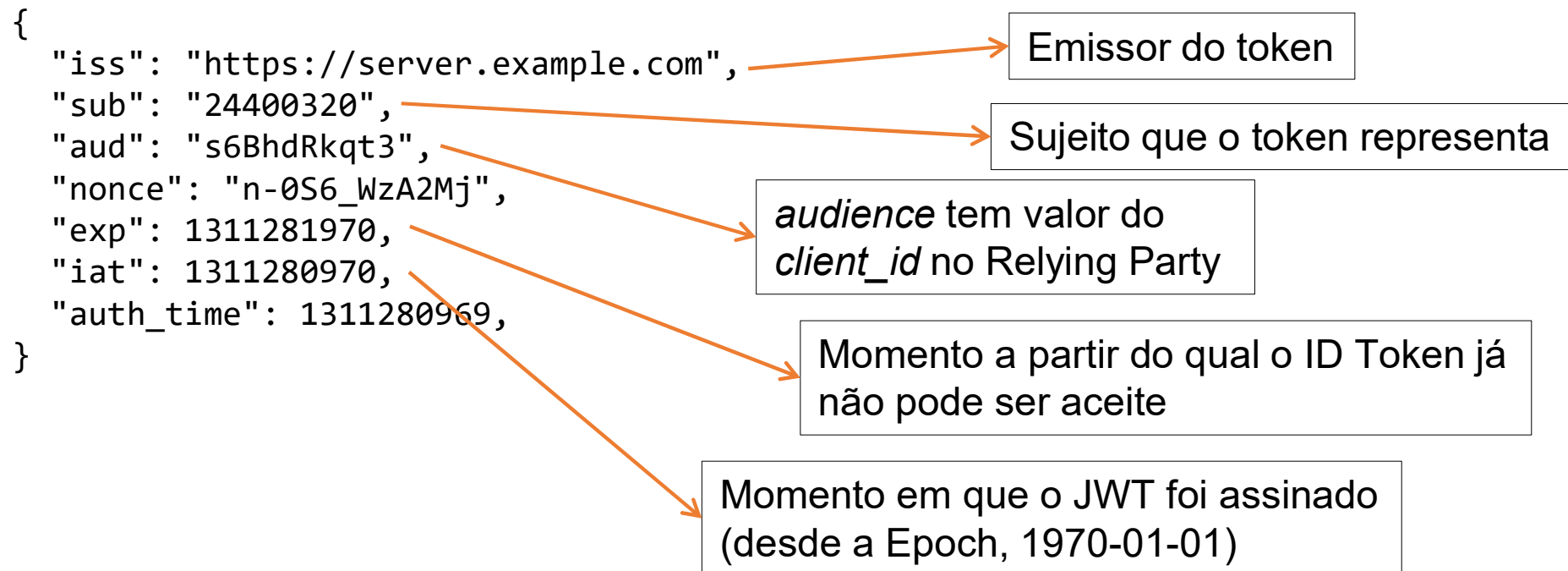
OP - *OpenID Provider / Identity Provider*

Fluxo do tipo *authorization code*



ID Token

- Um ID token é um conjunto de asserções sobre um utilizador autenticado
- JSON Web Token (JWT) assinado pelo fornecedor de identidade



Recurso UserInfo

- A informação sobre um utilizador autenticado pode ser obtida através do UserInfo Endpoint
- Representada através de um objecto JSON
 - se assinada/cifrada será um JWT [5]
- Exemplo com *UserInfo endpoint*
<https://www.googleapis.com/oauth2/v3/userinfo>

```
{  
  "family_name": "Surname",  
  "name": "Alice",  
  "picture": "...",  
  "email": "alice@gmail.com",  
  "gender": "female",  
  "link": "https://plus.google.com/...",  
  "given_name": "Alice",  
  "id": "100...2243139"  
}
```

Fluxos e Respostas

- https://openid.net/specs/openid-connect-core-1_0.html#Overview

Property	Authorization Code Flow	Implicit Flow	Hybrid Flow
All tokens returned from Authorization Endpoint	no	yes	no
All tokens returned from Token Endpoint	yes	no	no
Tokens not revealed to User Agent	yes	no	no
Client can be authenticated	yes	no	yes
Refresh Token possible	yes	no	yes
Communication in one round trip	no	yes	no
Most communication server-to-server	yes	no	varies

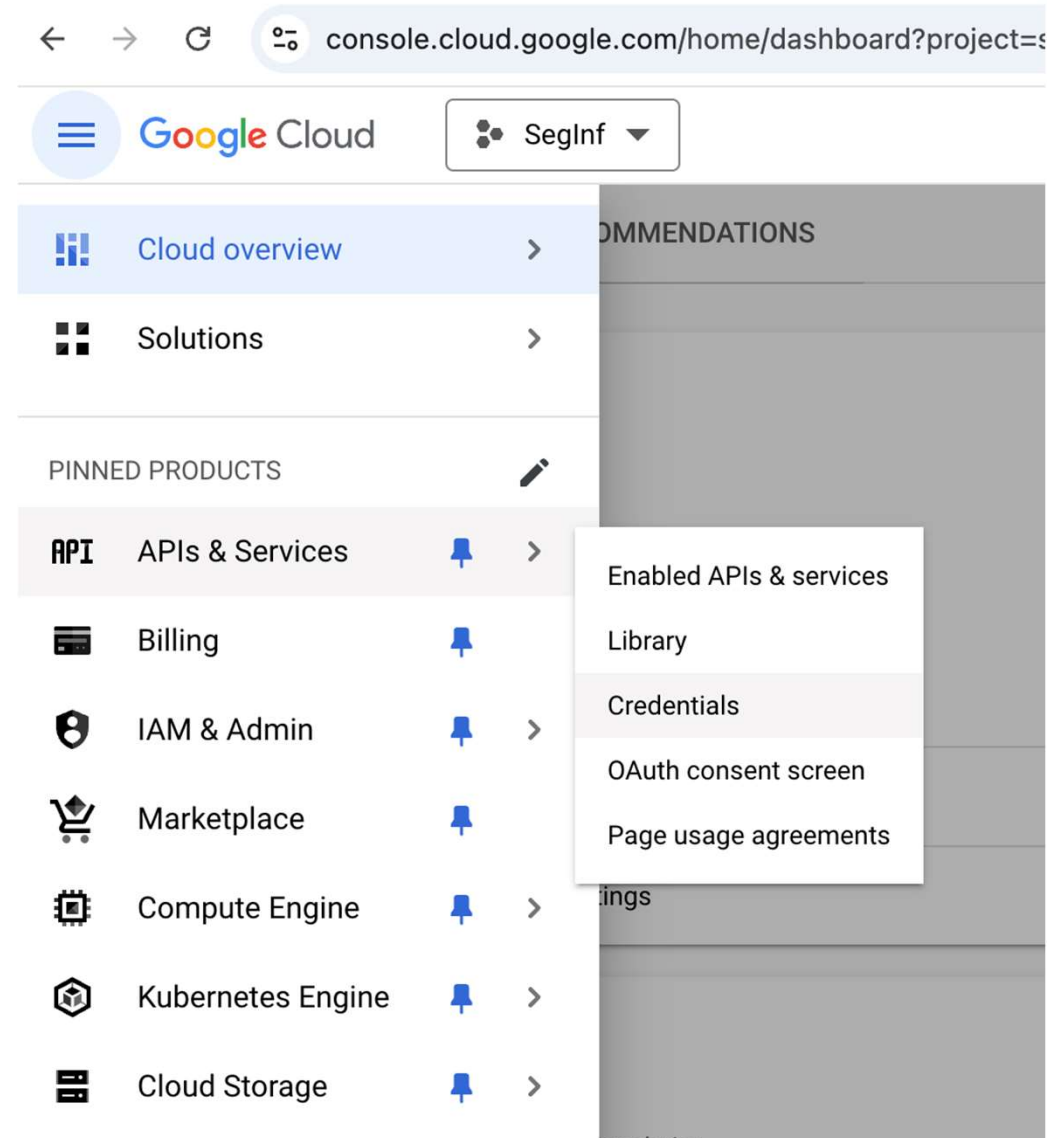
OpenID Connect Authentication Flows

"response_type" value	Flow
code	Authorization Code Flow
id_token	Implicit Flow
id_token token	Implicit Flow
code id_token	Hybrid Flow
code token	Hybrid Flow
code id_token token	Hybrid Flow

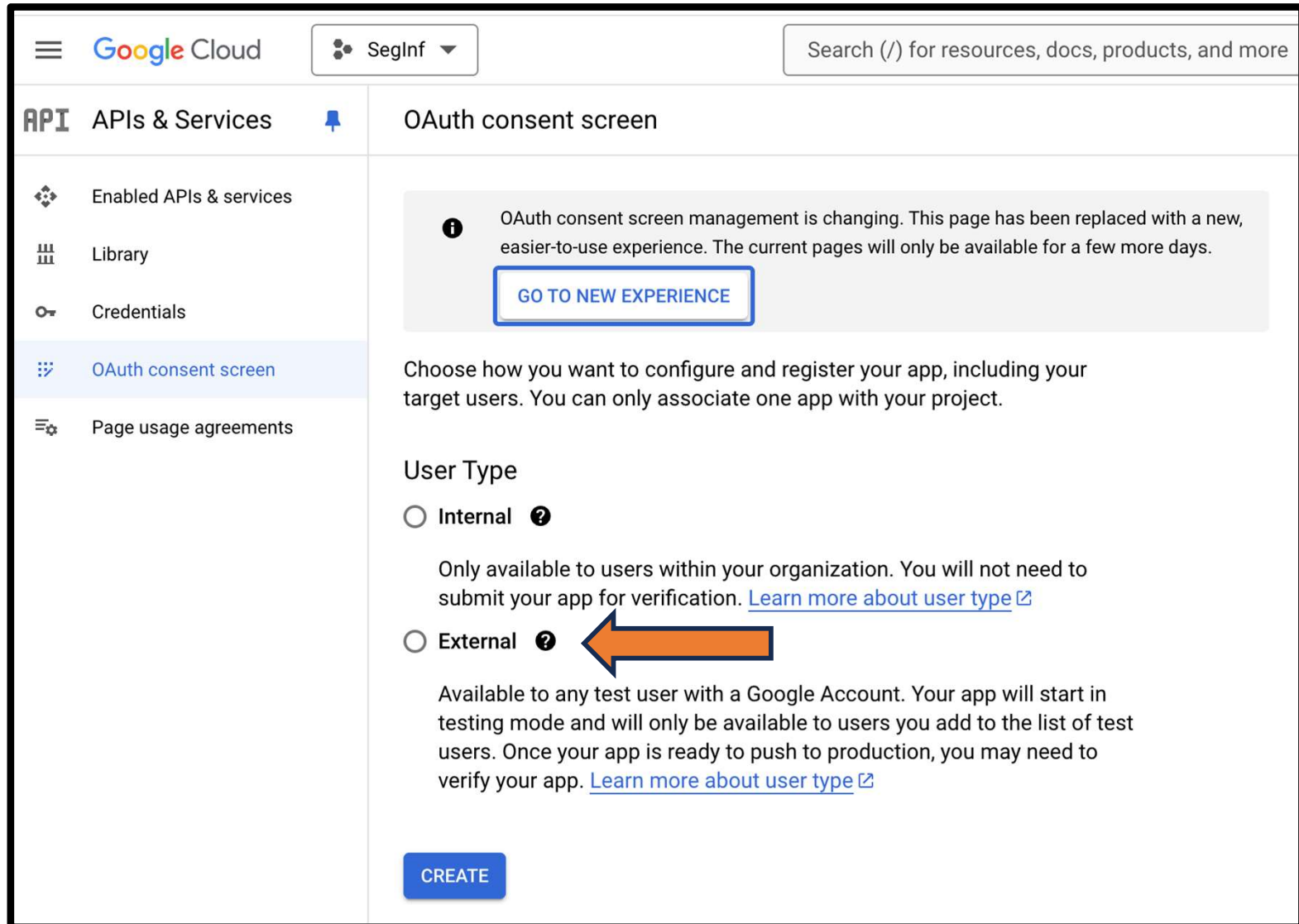
OpenID Connect "response_type" Values

Obtenção de credenciais

- O registo de novos *relying party* e obtenção das credenciais a usar pelo *relying party* (`cliente_id` e `client_secret`) depende do fornecedor de identidade
- No caso da Google, o processo é feito através da Google Cloud Platform (GCP)
- <https://console.cloud.google.com/>
- API & Services > Credentials
- Não há custos monetários neste processo de registo e obtenção de credenciais



Obter credenciais (i)



The screenshot shows the Google Cloud console interface for configuring an OAuth consent screen. The left sidebar contains the 'APIs & Services' menu with options: 'Enabled APIs & services', 'Library', 'Credentials', 'OAuth consent screen' (highlighted), and 'Page usage agreements'. The main content area is titled 'OAuth consent screen'. At the top, there is a search bar and a 'SegInf' dropdown. A notification banner states: 'OAuth consent screen management is changing. This page has been replaced with a new, easier-to-use experience. The current pages will only be available for a few more days.' Below this is a button labeled 'GO TO NEW EXPERIENCE'. The main configuration section is titled 'Choose how you want to configure and register your app, including your target users. You can only associate one app with your project.' Under the 'User Type' heading, there are two radio button options: 'Internal' and 'External'. The 'External' option is selected, indicated by an orange arrow pointing to it. Below each option is a description and a link to 'Learn more about user type'. At the bottom of the configuration section is a blue 'CREATE' button.

Google Cloud

SegInf

Search (/) for resources, docs, products, and more

API APIs & Services

- Enabled APIs & services
- Library
- Credentials
- OAuth consent screen**
- Page usage agreements

OAuth consent screen

OAuth consent screen management is changing. This page has been replaced with a new, easier-to-use experience. The current pages will only be available for a few more days.

[GO TO NEW EXPERIENCE](#)

Choose how you want to configure and register your app, including your target users. You can only associate one app with your project.

User Type

☐ Internal ?

Only available to users within your organization. You will not need to submit your app for verification. [Learn more about user type](#)

☒ External ?

Available to any test user with a Google Account. Your app will start in testing mode and will only be available to users you add to the list of test users. Once your app is ready to push to production, you may need to verify your app. [Learn more about user type](#)

[CREATE](#)

Configurações gerais (i)

Google Cloud Segling Demos Project Search (/) for resources, docs, p

Google Auth Platform Project configuration

Overview Branding Audience Clients Data Access Verification Center

1 App Information

2 Audience

☐ Internal ?

Only available to users within your organization. You will not need to submit your app for verification. [Learn more about user type](#)

☒ External ?

Available to any test user with a Google Account. Your app will start in testing mode and will only be available to users you add to the list of test users. Once your app is ready to push to production, you may need to verify your app. [Learn more about user type](#)

NEXT

3 Contact Information

4 Finish

CREATE CANCEL

Configurações gerais (ii)

- Em modo de utilizadores externos, os endereços de email dos diferentes utilizadores que podem usar o relying party e, consequentemente, o *authorization server* têm de ser explicitamente indicados

The screenshot displays the Google Cloud console interface for the 'Segling Demos Project'. The left sidebar shows the 'Google Auth Platform' menu with options: Overview, Branding, Audience (highlighted with an orange arrow), Clients, Data Access, and Verification Center. The main content area is titled 'Audience' and includes sections for 'Publishing status' (with a 'PUBLISH APP' button), 'User type' (set to 'External' with a 'MAKE INTERNAL' link), and 'OAuth user cap' (showing a progress bar for '1 user (1 test, 0 other) / 100 user cap'). The 'Test users' section features a '+ ADD USERS' button (highlighted with an orange arrow) and a table of test users. The table has a 'Filter' header and one entry: 'User information' with the email 'jose.m.simao@gmail.com' and a delete icon.

Obter client-id e client-secret (2)

Preencher
campos
obrigatórios

Não preencher

Email Google
do próprio e
dos colegas

Learn more'. There is a '+ ADD USERS' button. Below this is a filter section with a 'Filter' label and a text input field 'Enter property name or value'. A table with the header 'User information' is partially visible, showing a row with a blue-outlined input field and a trash icon. At the bottom are 'SAVE AND CONTINUE' and 'CANCEL' buttons."/>

Edit app registration

✓ OAuth consent screen — ✓ Scopes — 3 **Test users** — 4 Summary

Test users

While publishing status is set to 'Testing,' only test users are able to access the app. Allowed user cap prior to app verification is 100, and is counted over the entire lifetime of the app. [Learn more](#)

+ ADD USERS

Filter Enter property name or value ?

User information	

SAVE AND CONTINUE CANCEL

Obter client-id e client-secret (3)

The screenshot displays the Google Cloud Platform console interface. On the left, the 'APIs and services' sidebar is visible, with 'Credentials' selected. The main content area shows the 'Create OAuth client ID' dialog. The dialog includes the following fields and options:

- Application type ***: Web application
- Name ***: My Demo 22/23
- Authorised JavaScript origins**: For use with requests from a browser. Includes a '+ ADD URI' button.
- Authorised redirect URIs**: For use with requests from a web server. Includes a text input field with 'http://localhost:3001/callback-demo2223' and a '+ ADD URI' button.
- Buttons**: CREATE (highlighted) and CANCEL.

A blue arrow points from the 'Credentials' section in the sidebar to the 'Create OAuth client ID' dialog.